

Requisitos Não Funcionais – Gateway PAVPLAS

ID	Categoria	Requisito Não Funcional
RNF-01	Desempenho	A tela de pagamento deve responder em até 3 segundos em 95% das requisições sob responsabilidade da aplicação.
RNF-02	Desempenho	Após o recebimento da confirmação do provedor, a atualização do status do pedido deve aparecer em até 10 segundos em 95% dos casos.
RNF-03	Disponibilidade	O sistema deve possuir disponibilidade mensal mínima de 99,5%, desconsiderando manutenções previamente avisadas.
RNF-04	Segurança / Autenticação	O sistema deve utilizar contas individuais, senhas protegidas por hash adaptativo, limitação de tentativas e recuperação segura.
RNF-05	Segurança / MFA	O painel interno deve exigir autenticação multifator para usuários que realizem operações críticas.
RNF-06	Segurança / Sessão	As sessões devem utilizar mecanismos seguros, incluindo cookies Secure, HttpOnly e SameSite quando aplicável, expiração por inatividade e invalidação após troca de senha ou revogação.
RNF-07	Segurança / Autorização	O acesso deve seguir o princípio do menor privilégio e ser validado no servidor conforme o perfil e as permissões do usuário.
RNF-08	Segurança / Segregação	As permissões devem impedir que usuários executem operações incompatíveis com suas funções, preservando a segregação entre comercial, financeiro, faturamento e expedição.
RNF-09	Privacidade	Cada cliente deve visualizar somente seus próprios dados, pedidos, pagamentos e documentos.
RNF-10	Segurança / Pagamentos	A confirmação do pagamento deve utilizar informações autenticadas do provedor; comprovantes enviados pelo cliente não devem ser a única fonte de confirmação.
RNF-11	Integridade	Cada cobrança deve possuir identificador único, valor esperado, pedido associado e validade; divergências devem impedir a liberação do pedido.
RNF-12	Webhooks	Webhooks devem validar assinatura/autenticidade e mecanismos de proteção contra replay e eventos inválidos.
RNF-13	Idempotência	Repetições ou atrasos de eventos não podem gerar cobranças, reservas, baixas ou expedições duplicadas.
RNF-14	Integridade do Pedido	O pedido deve seguir estados válidos, impedindo a passagem para expedição sem o cumprimento das etapas obrigatórias.
RNF-15	Criptografia	Toda comunicação entre cliente, aplicação e serviços externos deve utilizar HTTPS/TLS com certificados válidos.
RNF-16	Proteção de Dados	Dados pessoais sensíveis, tokens, comprovantes, backups e documentos que necessitem proteção devem possuir criptografia em repouso.

RNF-17	Gestão de Segredos	Chaves de API, certificados e credenciais devem ser armazenados de forma segura e fora do código-fonte
RNF-18	Segurança de API	A API deve validar autenticação, autorização, tipos, formatos, tamanhos, limites e conteúdo dos dados recebidos no servidor.
RNF-19	Proteção contra Ataques	Devem ser aplicados controles contra injeção, XSS, CSRF, força bruta, abuso de endpoints e uploads maliciosos, quando aplicáveis.
RNF-20	Resiliência	Endpoints e integrações críticas devem possuir timeout, rate limiting, retentativas controladas e mecanismos de tolerância a falhas conforme aplicável.
RNF-21	Privacidade / LGPD	O sistema deve coletar somente os dados necessários, informar as finalidades e controlar o compartilhamento com terceiros previstos no projeto.
RNF-22	Retenção	Dados, comprovantes e logs devem possuir política de retenção e descarte compatível com as necessidades operacionais e obrigações legais.
RNF-23	Auditoria	O sistema deve registrar logins, falhas, alterações de pedidos, mudanças de preço, pagamentos, aprovações, webhooks e integrações relevantes.
RNF-24	Proteção de Logs	Os logs devem ser protegidos contra alteração ou exclusão indevida e devem mascarar senhas, tokens e dados financeiros sensíveis.
RNF-25	Monitoramento	O sistema deve gerar alertas para falhas relevantes, como tentativas repetidas de login, falhas de webhook, divergências financeiras e comportamento anômalo.
RNF-26	Continuidade	Os backups devem ser protegidos, possuir controle de acesso, verificação de integridade e testes periódicos de restauração.
RNF-27	Escalabilidade	A aplicação deve suportar pelo menos 100 solicitações simultâneas, com taxa de erro inferior a 1%, conforme o ambiente de teste definido.
RNF-28	Usabilidade	O fluxo deve funcionar em celular e computador, informar valores e status antes da confirmação e apresentar mensagens compreensíveis em caso de erro.
RNF-29	Observabilidade	As operações devem gerar registros com data, identificador do pedido, status e código de erro, sem registrar dados sensíveis.
RNF-30	Recuperação	Os registros de pedidos e pagamentos devem possuir backup diário, com meta de RPO de até 24 horas e RTO de até 4 horas.
RNF-31	Desempenho Logístico	A consulta ao Melhor Envio e a consolidação do frete no checkout devem responder em até 2 segundos em 95% das requisições, em condições normais.
RNF-32	Resiliência de Integrações	Caso o ERP ou WMS esteja indisponível após uma aprovação, o evento deve permanecer retido e possuir retentativas com backoff por até 24 horas.
RNF-33	Manutenibilidade / Processo	O desenvolvimento deve incluir revisão de código, análise de dependências, testes de segurança e correção de vulnerabilidades antes da produção.

